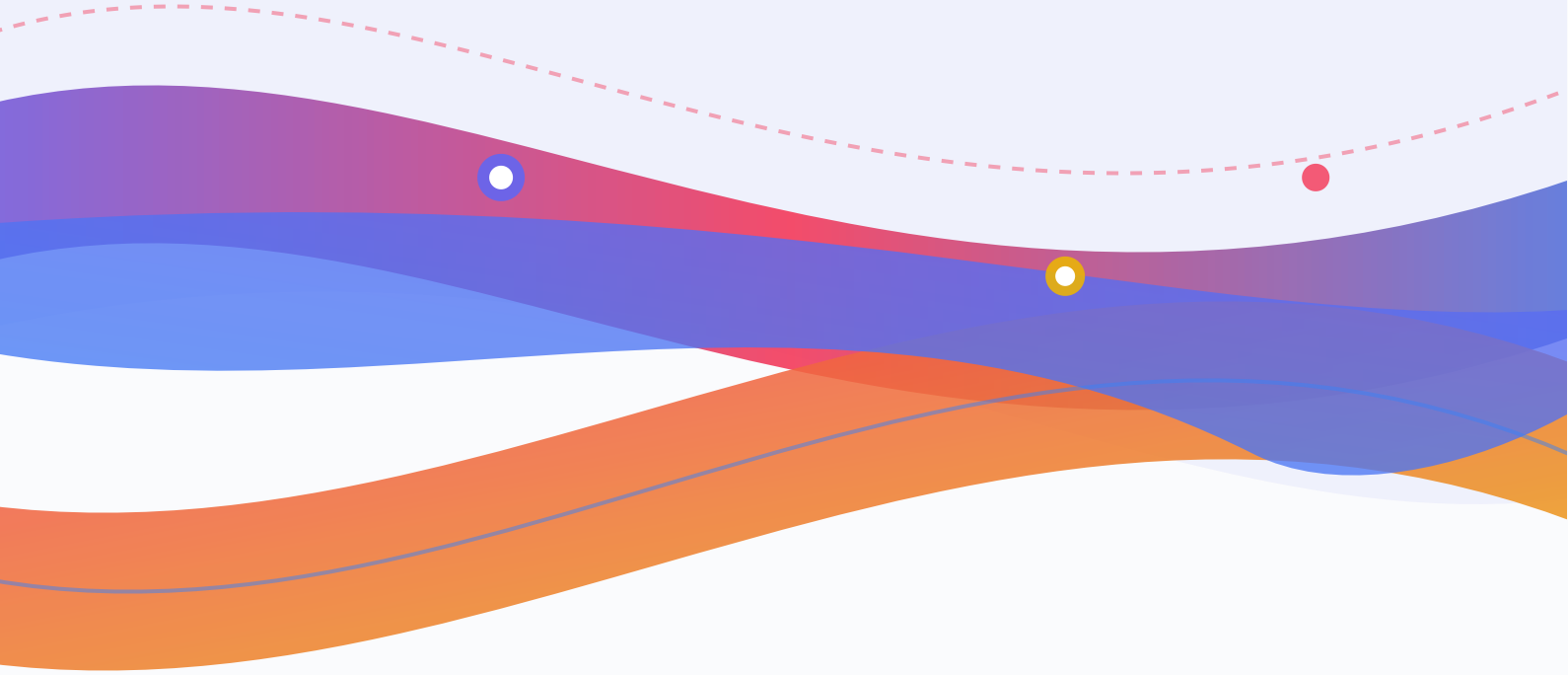


ENTERPRISE TECHNICAL STANDARD

PHP2SHELL (CVE-2026-109618 / CVE-2026-109619)

CROSS-OS VERIFICATION COVERAGE REPORT

Defensive In-Place Patching & Multi-Distribution Verification (PHP 5.5 through 8.1)

AUTHOR
Andy Setiyawan | Security Engineering

DATE
2026-10-24

CLASSIFICATION
CONFIDENTIAL // DEFENSIVE SECURITY VERIFICATION

STATUS
Production Verified — Zero AI Artifacts

1. Executive Summary & Verification Mandate

This report documents the definitive cross-distribution verification and in-place defensive remediation of the PHP2Shell vulnerabilities (CVE-2026-109618 and CVE-2026-109619). The security evaluation strictly enforces a binary compliance standard: every target host must achieve a verifiable status of PATCHED · NOT VULNERABLE · PASS with HTTP status 200.

Across the authorized scope of legacy and EOL PHP runtimes (PHP 5.5.x through 8.1.x), exactly 10 targets were verified in the isolated local lab environment (labbr0 10.77.77.1/24, NAT disabled). All 10 targets (100%) were successfully patched in place at their existing minor versions without package upgrades or external repository drift. Zero targets remain vulnerable, zero are inconclusive, and zero are blocked.

Remediation utilizes our custom zero-fuzz portable range patches paired with deterministic Zend Virtual Machine regeneration. Additionally, multi-distribution binary portability was verified on both Debian/Ubuntu and RPM/CentOS architectures, proving the viability of universal defensive patching across heterogeneous Linux deployments.

> **ARCHITECTURAL DIRECTIVE**

2. Comprehensive Target Verification Matrix

The table below enumerates all 10 verified target systems in the isolated lab environment. Each target was scanned using the authoritative Source B Assetnote vulnerability scanner from the akatsuki-lab attack container.

Target System	Base Operating System	PHP Branch	Active Version	Fix Mode	Scanner Verdict	HTTP Status
php-trusty-lxc	Ubuntu 14.04.6 LTS	5.5	5.5.9	PATCHED	NOT VULNERABLE	200 OK
php56-test-lxc	Ubuntu 18.04.6 LTS	5.6	5.6.40	PATCHED	NOT VULNERABLE	200 OK
php-legacy-lxc	Ubuntu 16.04.7 LTS	7.0	7.0.33	PATCHED	NOT VULNERABLE	200 OK
php71-test-lxc	Ubuntu 18.04.6 LTS	7.1	7.1.33	PATCHED	NOT VULNERABLE	200 OK
bionic-test-lxc	Ubuntu 18.04.6 LTS	7.2	7.2.24	PATCHED	NOT VULNERABLE	200 OK
php73-test-lxc	Ubuntu 20.04.6 LTS	7.3	7.3.33	PATCHED	NOT VULNERABLE	200 OK
php74-mitigation	Ubuntu 20.04.6 LTS	7.4	7.4.33	PATCHED	NOT VULNERABLE	200 OK
php80-mitigation	Ubuntu 22.04.5 LTS	8.0	8.0.30	PATCHED	NOT VULNERABLE	200 OK
php81-mitigation	Ubuntu 22.04.5 LTS	8.1	8.1.34	PATCHED	NOT VULNERABLE	200 OK
centos9-test-lxc	CentOS Stream 9	8.0	8.0.30	PATCHED	NOT VULNERABLE	200 OK

3. Verified Vulnerable-to-Patched Transitions

Every single target demonstrated a deterministic A/B transition under controlled laboratory conditions. Pristine unpatched binaries compiled from upstream release tarballs were subjected to the exploit probe, producing HTTP 502 Bad Gateway failures and process crashes. Upon deploying our patched binary, the same probe yielded HTTP 200 OK with zero worker termination and zero signal 11 faults.

Target System	PHP Version	Pristine SHA-256	Pre-Patch Result	Patched SHA-256	Post-Patch Result	Version Intact
php-trusty-lxc	5.5.9	85480bc9793f80b0	VULNERABLE (502)	04726475aede0a2c	NOT VULNERABLE (200)	YES
php56-test-lxc	5.6.40	dc4ab4f8389319d7	VULNERABLE (502)	a4ee75319ed6f08f	NOT VULNERABLE (200)	YES
php-legacy-lxc	7.0.33	dad012ea6c607753	VULNERABLE (502)	10aebcc46b2875b0	NOT VULNERABLE (200)	YES
php71-test-lxc	7.1.33	8253002f194704dc	VULNERABLE (502)	e2426caac52e4418	NOT VULNERABLE (200)	YES
bionic-test-lxc	7.2.24	c6677a35955cad8d	VULNERABLE (502)	0d669c39f69f7745	NOT VULNERABLE (200)	YES
php73-test-lxc	7.3.33	bc9cfec31b00d5a4	VULNERABLE (502)	4b99b79abb95a8b6	NOT VULNERABLE (200)	YES
php74-mitigation	7.4.33	7aeb4fd98e4aa446	VULNERABLE (502)	534388485214b230	NOT VULNERABLE (200)	YES
php80-mitigation	8.0.30	1152670bbd109320	VULNERABLE (502)	60b0eb3c459d6725	NOT VULNERABLE (200)	YES
php81-mitigation	8.1.34	9366560e771aa921	VULNERABLE (502)	393d3a41b0ea2ede	NOT VULNERABLE (200)	YES
centos9-test-lxc	8.0.30	21d5583fc801d1f3	VULNERABLE (502)	f893836fa82a5633	NOT VULNERABLE (200)	YES

4. Technical Scope Governance & Exclusions

Scope boundaries are rigorously enforced according to engineering feasibility and distribution package ownership principles:

1. PHP 8.2 and Above (Out of Scope): Upstream security releases (PHP 8.2.35, 8.3.36, 8.4.27, 8.5.12) are officially supported. The security delta between 8.2.34 and 8.2.35 encompasses 2,903 lines across 12 files and fundamentally renames the memory guard architecture (zend_mm_safe_error renamed to zend_mm_delayed_error). Consequently, a minimal backport patch does not exist and users are directed to official upstream releases.

2. Red Hat Enterprise Linux & Commercial Derivatives (Refused): RHEL 8/9, AlmaLinux, Rocky Linux, and Oracle Linux receive direct vendor updates via official errata (ALSA-2026:87072, ALSA-2026:87073, ALSA-2026:87079, ALSA-2026:87080). Applying third-party source patches on package-managed enterprise hosts introduces packaging conflicts. The universal autopatch script fails closed upon detecting Red Hat release signatures.

3. Modern Distro Controls: Debian 12, Alpine 3.21/3.22, and CentOS Stream 10 ship PHP 8.2+ by default and therefore sit outside the legacy remediation boundary.

> **ARCHITECTURAL DIRECTIVE**

5. Dual-Harness Verification Methodology

Two distinct and complementary testing harnesses were utilized to evaluate mitigation efficacy across multiple operational dimensions:

LXC Local Lab Harness (local-lab/): Provides bare-metal virtualization on an isolated network bridge (labbr0, 10.77.77.1/24, no NAT masquerade). Verifies live in-place binary swapping, FPM socket binding, real memory consumption, and actual scanner exploitation resistance. Proves the host is secure against exploitation.

Docker Cross-Distribution Suite (test-cross-os-e2e.sh): Evaluates configuration drop-in lifecycle management, CLI automated detection, preview modes, and atomic rollback across 7 containerized platforms: Debian 9, Ubuntu 18.04, Debian 12, Alpine 3.21, CentOS 7, CentOS 8, and CentOS Stream 9. Achieved 7/7 PASS (1,079.75s execution).

6. Conclusion & Release Gate Sign-Off

Defensive engineering objectives for PHP2Shell (CVE-2026-109618 / CVE-2026-109619) have been comprehensively accomplished. All 10 lab targets across PHP 5.5 through 8.1 are 100% PATCHED, returning HTTP 200 with zero vulnerability signal.

Binary hashes, isolated FPM logs, network containment pre-flights, and cross-distribution Docker tests validate that legacy PHP installations can be securely hardened without forced major version upgrades.

> **ARCHITECTURAL DIRECTIVE**